



COMPUTER SECURITY

Lecture 1: Introduction To Computer Security

Prof. Dr. Noha Hikal

**Information Technology Dept.
Vice dean for Community Services and Environmental Development**

COURSE CARD

Course Code	IT424P			
Course Name	Computer Security			
Core/Elective	Core			
Credits	Theory: 2	Project: 0	Lab: 3	TOT: 3
Course Description	This course is intended as a basic introduction to computer security and cryptography. It is an introductory course to concepts in information security and management.			
Course Syllabus	• Principles of computer security. • Basic cryptography. • Authentication. • Secure network protocols (Kerberos, SSL). • Program security (Bug exploits, Malicious code: viruses, worms, trojan horses). • Attacks and defenses on computer systems (Firewalls, Intrusion detection, Countermeasures) . • Trusted operating systems. • Ethical and legal issues in computer security. • Developing security plans for a system.			

Course Contents:

- Computer Security Terminologies and fundamentals
- Cryptography
- SW and OS security
- DB security
- NW security
- Authentication techniques

Course Material

- Textbook : Security in Computing by Pfleeger , 4st edition, 2006.

ISDN # 0132390779.

- Lecture notes

- Internet Resource

Evaluation Procedure:

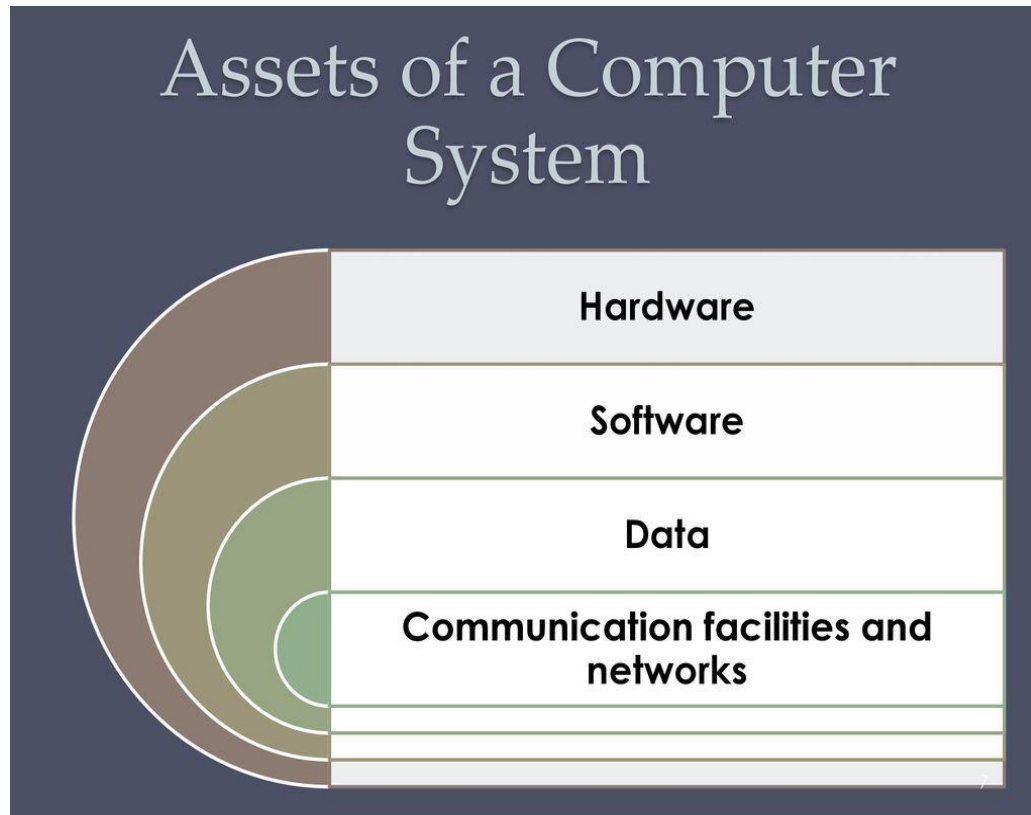
- Assignments: 10
- Midterm Exam: 10
- Oral Exam: 10
- Practical Exam: 10
- Final Exam: 60

Computer security

The NIST Computer Security Handbook [NIST95] defines the term computer security as:

"The protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability, and confidentiality of information system resources (includes hardware, software, firmware, information/ data, and telecommunications)."

Assets of Computer System



+ Peopleware

Assets (Cont.)



Hardware:

- Computer
- Devices (disk drives, memory, printer)
- Network gear

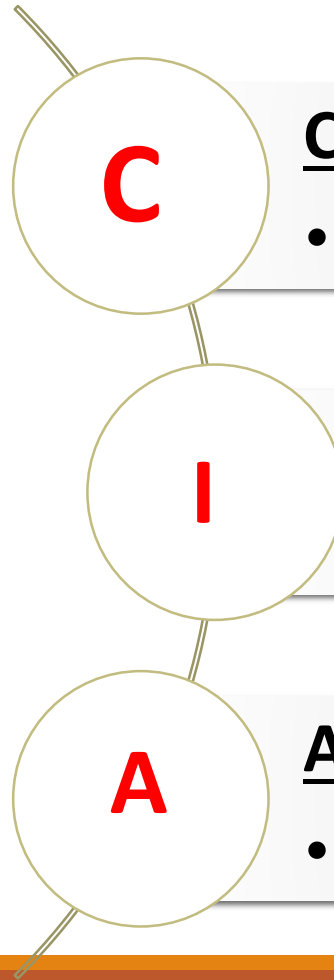
Software:

- Operating system
- Utilities (antivirus)
- Commercial applications (word processing, photo editing)
- Individual applications

Data:

- Documents
- Photos
- Music, videos
- Email
- Class projects

Basic Security Goals



C

Confidentiality

- The need for keeping information secret

I

Integrity

- Trustworthiness of data or resources

A

Availability

- The ability to use the information or resource.

Confidentiality

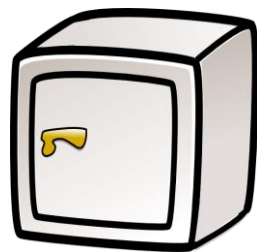
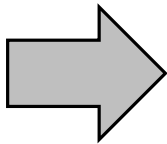
Definition: is concealment of information or resources.

The need of keeping the information confident depends on the sensitivity of the information.

- E.g. Military information vs. industrial information vs. personal information.

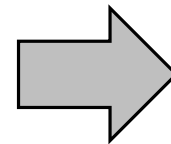
Achieving higher confidentiality is supported by:

- Access Control: Ensures only authorized personnel have access to the information.
- Cryptography: When unauthorized access occurred, information is meaningless.

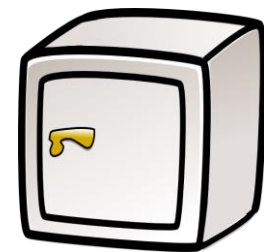
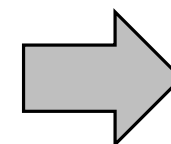


Readable &
accessible

Readable &
NOT accessible



NOT Readable
But accessible



NOT Readable
NOT accessible

Integrity

Definition: Trust worthiness of the data or resource. Prevent improper or unauthorized change.

Integrity includes:

- Data integrity: Content of the data.
- Origin integrity : Source of the data using authentication.

Integrity Mechanism falls into two classes:

- Prevention: Blocking unauthorized attempt to modify data.
- Detection: Report when unauthorized modification occurs.

Evaluating integrity is hard because some attempts seems legit.

10001100



internet

10001100



© Can Stock Photo

Availability

Definition: Ensures that authorized access to data when desired.

Attempt to block service (System down) or make the service unavailable is called Denial of service attack (DoS).



Continue security Goals

..

Availability (Vs denial of service) access to computing resources without difficulties.)

Expectations of availability:

1. Presence of object or service in usable form
2. Capacity to meet service needs
3. Progress : Bounded waiting time
4. Adequate time/ timeliness of service

The Goals of availability:

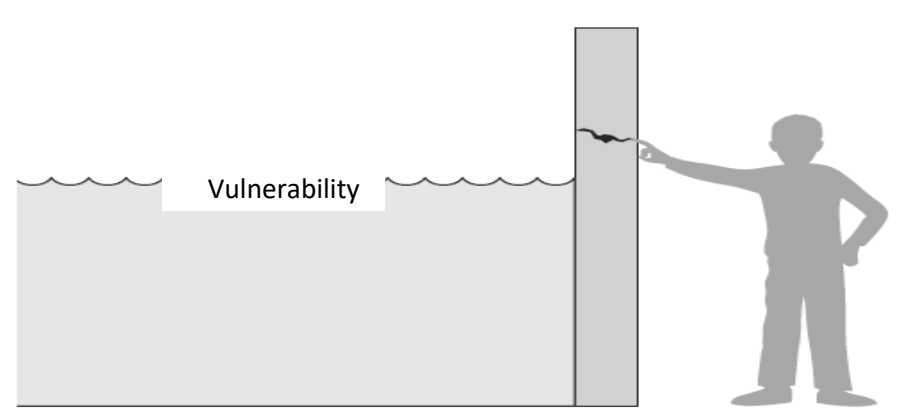
1. Timely response
2. Fair allocation
3. Fault tolerance
4. Usability (can be used as intended)
5. Controlled concurrency (support of simultaneous access, deadlock management)

Threats vs Vulnerability

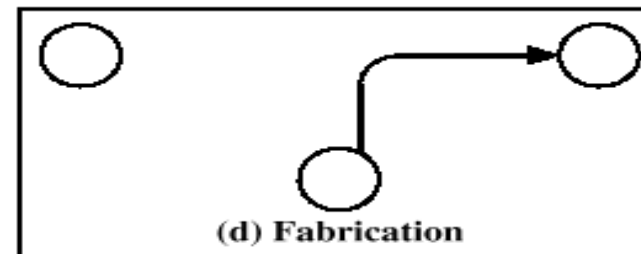
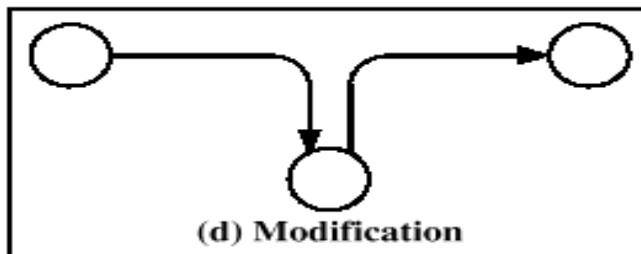
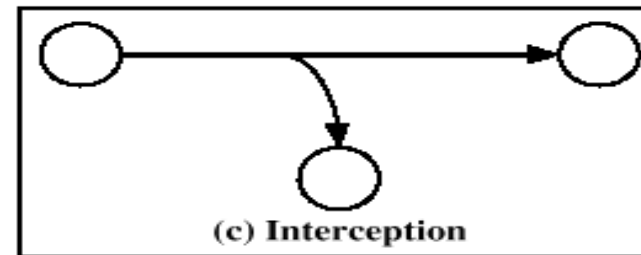
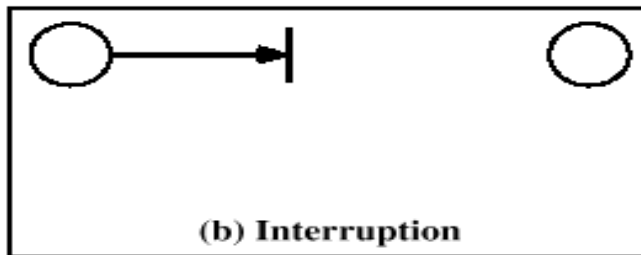
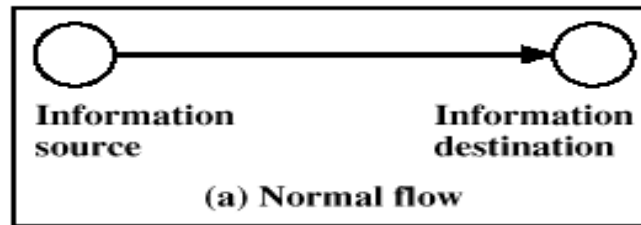
Threats : A loss or harm that might be fall a system , e.g., users' personal files may be revealed to the public

Vulnerability: it refers to a weakness in the computer system (i,e; policy, design, implementation, or procedure) that can be exploited to cause harm or loss

- There are four major categories of threats:
 - Interception
 - Interruption
 - Modification
 - Fabrication



Actions of threats



Threats to the security of a computing system

- **Interruption:** an asset of the system becomes lost, unavailable or unusable (example: Destruction of hardware, erasure of program or data or malfunction of an OS file manager .
- **Interception:** means that some unauthorized party (person, program) has gain access to an asset (example: illicit copying of program or data files, or wiretapping to obtain data in a network.)
- **Modification:** Example(changing the values in a database modifying a program so that it performs an additional computation, or modifying data being transmitted by the network).
- **Fabrication :** counterfeit objects on a computing system. (adding records to an existing data base or insertion of spurious transactions to a network communication system.

Continued.

Threats to hardware: (Usually The concern of a small staff of computer center professionals)

- Involuntary(water, food, burned, gas ,dust, slap, punch)
- Voluntary: in which some actually wishes to do harm to the computer (bombs ,fires, ,theft, shorting out circuit boards)

Threats of software(the concern of all programmers and analysts who create and modify programs)

1. Software deletion.
2. Software theft.
3. Software modification (either to cause the program fails during execution or fails in some special circumstances(logic bomb) or to cause it to do some unintended task.

The category of software modification include:

- **Trojan horse**- a program that overtly does one thing while covertly doing another
- **Virus** – a specific type of Trojan horse, that can be used to spread infection from one computer to another.
- **Trapdoor**- a program that has a secret entry point.
- **Information leaks** –in a program which make information accessible to unintended people or programs.

Continued.

Threats of data(the concern of general public, so data attack is a more widespread and serious problem than either hardware or software) examples:

- Confidential data leaked to a competitor may narrow a competitive edge.
- Data incorrectly modified can cost human lives

The qualities of data security;

1. **Confidentiality** – (preventing unauthorized disclosure): data can be gathered by tapping wires planting bugs in output devices, from trashes, monitoring electromagnetic radiation, bribing key employees, inferring on data point from other values.
2. **Data integrity** –(preventing unauthorized modification) modifying or making a new data requires understanding the technology by which data stored transmitted and it's format ,and this might be done by using malicious programs Example(**salami attack**)
3. **Availability** (preventing denial of authorized access)

Continued.

Other exposed assets

Storage media (effective security plans consider adequate backups of data and physical protection for the media contains these backups.

Networks – a collections of software, hardware , and data and this simply multiply the problem of security.

Access to computer equipment (the intruder may steal computer time just to do computing and he can destroy software or data and this may lead to the denial of the service to a legitimate user .

Key People (if only one person knows how to use or maintain a particular program –trouble can arise if he gets sick, has an accident or leaves ,

- disgruntled employees can cause serious damage
- Trusted individuals should be selected carefully

Threats to computer Networks

Interception	• Unauthorized viewing	Eavesdropping or wiretapping
Modification	• Unauthorized change	Integrity failure
Fabrication	• Unauthorized creation	Integrity failure
Interruption	• Preventing authorized access	Denial of service

Defense of computer systems

- Cryptography
Protecting data by making it unreadable to an attacker
- Authenticating users with digital signatures
- Authenticating transactions with cryptographic protocols
- Ensuring the integrity of stored data

Continued.

Software controls

- Passwords and other forms of access control
- Operating systems separate users' actions from each other
- Virus scanners watch for some kinds of malware
- Development controls enforce quality measures on the original source code
- Personal firewalls that run on your desktop

Continued.

Hardware controls

- Not usually protection of the hardware itself, but rather using separate hardware to protect the system as a whole
- Fingerprint readers
- Smart tokens
- Firewalls
- Intrusion detection systems

Continued.

Physical controls

- Protection of the hardware itself, as well as physical access to the console, storage media, etc.
- Locks
- Guards
- Off-site backups

Continued.

- Policies and procedures
- Non-technical means can be used to protect against some classes of attack
- Rules about changing passwords
- Training in best security practices

Methods of defense

countermeasures that attempt to prevent exploitation of the vulnerability of computing system.

- 1. Encryption :** Transforming data so that it is unintelligible to the outside observer, the most powerful tool in providing computer security and it provides confidentiality , integrity furthermore encryption is the basic of some protocols which insure availability of resources.
- 2. Software controls:** Programs must be secure to exclude outside attack and they must be maintained so that one can be confident of the dependability of them. Software controls may use tools such as hardware, encryption, or information gathering

Program controls include the following:

- **Internal program controls:** parts of the program that enforce security restriction such as access limitation in a data base management system .
- **OS Controls:** limitations enforced By the **OS** to protect each user from other users
- **Development controls:** Quality standards under which program is designed , coded, tested und maintained

Continued.

3. **Hardware controls** (hardware or smartcard implementation of encryption to locks limitation access, to theft protection, to circuit boards that control access to disk drivers in PCs.)
4. **Polices** examples:
 - **Frequent changing passwords**
 - **Legal controls**
 - **Ethical controls**
 - **Training and administration**
5. **Physical controls:** include (locks on doors, guards at entry points, backup copies of important software and data and physical site planning that reduces the risk of natural disasters)

To achieve Goals of Security

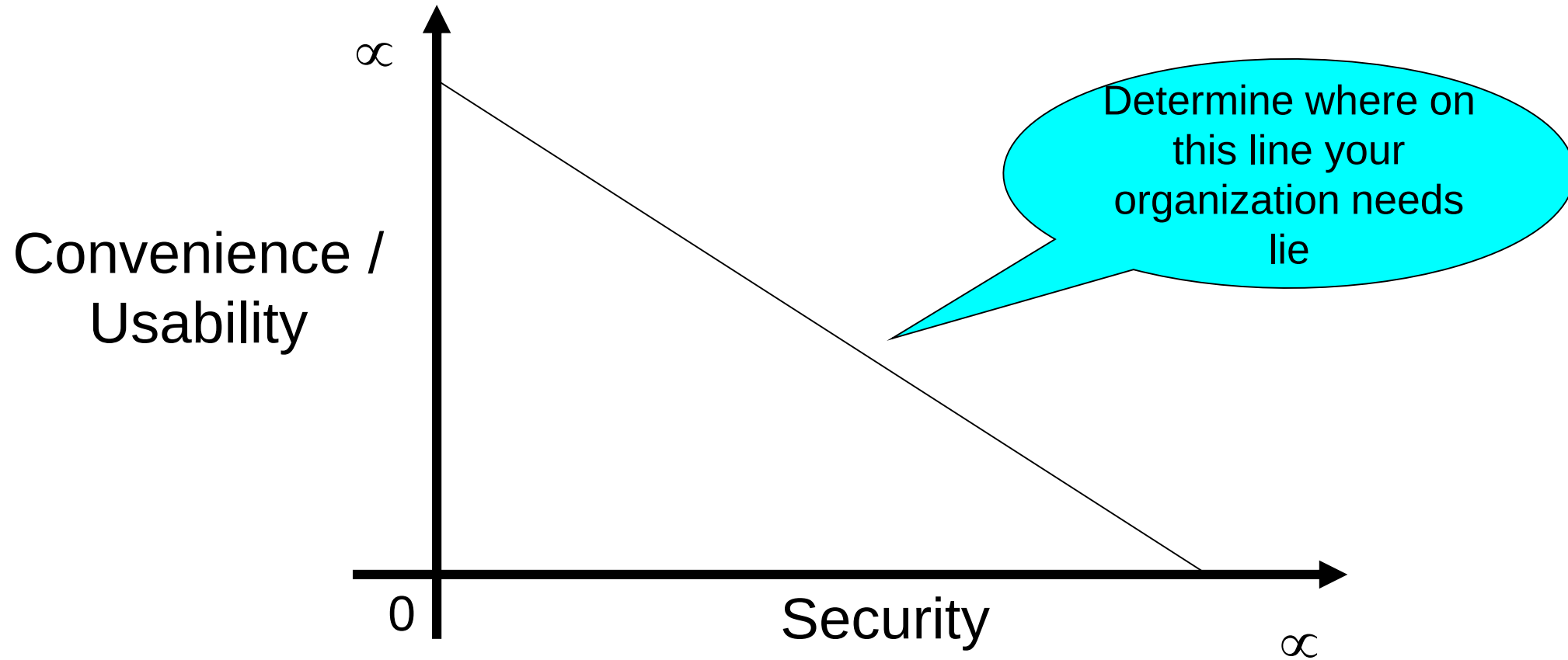


- The attack will fail.
- Involves implementation of mechanisms that users cannot override.
- Must be implemented correctly & unalterable way.
- Attackers must not be able to beat this mechanism

- It is useful when an attack can not be prevented.
- An indication of the effectiveness of prevention mechanism.
- Accept that an attack will occur, the goal is to determine that an attack on the way.

- A complex process because attacks are different.
- Two ways to recover:
 1. Stop the attack and to assess & repair and damage caused by the attacker.
 2. Recover the system to function.

Usability vs Security



factors that affect the effectiveness of controls

1. **Awareness of problem (people using controls must be convinced of the need for security)**
2. **Likelihood of use (no control is effective until it is used)**
3. **Overlapping controls (several different controls may be used)**
4. **Periodic review (continuous efforts to improve the methods of defense)**

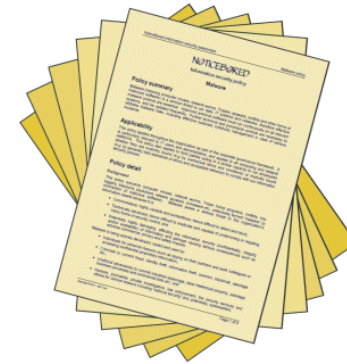
Policy and Mechanism

Security Policy: is the statement of what is, and what is not allowed.

Policy can be presented in mathematical form.

- Example: Binary matrices of what is allowed and what is not.

Usually policies are written in **English** language.



Policy and Mechanism (cont.)

Security Mechanism: is the method or tool or procedure for enforcing a security policy.

Mechanism can be nontechnical.

- Example: Presenting your ID (Physically) to change your bank phone number.

Mechanism Can be Technical.

- Example: You must change your password every 6 months.

Operational issues

It is a trade off between cost, implementation and mechanism verses policy and mechanism .

Cost-Benefit Analysis:

The total cost of the system determines how much many to invest in security.

If data cost less than the cost of protecting it, then investing in security mechanism is cost-effective.

Risk analysis:

- Risk is a function of environment : Attacker from overseas can not attack an offline system.
- Risk changes with time: Amazon down-time during Christmas is catastrophic.
- Risk is remote but still exist: companies allow internet access to some computers not all. Because it is acceptable to some.

THANK YOU

